AD HARDENING CHECKLIST

Active Directory security checklist

We're the pentesters behind Insight Recon. This is the Active Directory security checklist we'd work through on any domain, in the order we'd fix things. Every item says why it matters and links the guidance behind it.

70 items · 12 groups · Updated November 2026

Progress: 0 of 70 done · Printed November 13, 2026

The free scan at insightrecon.com checks 51 of these 70 items for you.

01 Before you change anything

0 of 5 done

Get a baseline and a way back before you touch anything. Cleanup goes a lot faster when a mistake is easy to undo.

- [ ] **Run a read-only assessment of every domain and keep the report**
  A dated report gives you a baseline to measure progress against later.
  DO FIRST **The free scan does this for one domain.** See every check it runs
  Sources: ASD/CISA/NSA · Microsoft

- [ ] **Write down your Tier 0**
  Your DCs, AD CS, AD FS and Entra Connect are Tier 0. So is anything that can control them. In most shops that means your backup, patching, hypervisor and EDR tools need DC-level protection too.
  DO FIRST **Check this by hand**
  Source: Microsoft

- [ ] **Look for signs you're already compromised**
  Hardening won't evict an attacker who already holds DCSync rights or a backdoor on AdminSDHolder. Find those before you start fixing anything.
  DO FIRST **Free scan checks part of this:** Possible DCShadow Activity · Risky DCSync Permissions · Risky AdminSDHolder Permissions · Privileged SIDs in sIDHistory · Stale Domain Controller Passwords
  The scan looks for what an intruder leaves in AD, like a DCShadow registration or extra DCSync rights. Your DC logs and EDR alerts are where the rest shows up.
  Sources: ASD/CISA/NSA · Microsoft

- [ ] **Confirm you have recent backups of at least two writable DCs per domain**
  If a change goes wrong or you find an intruder, you'll want a clean restore point. You can't restore a backup older than the tombstone lifetime, which is 180 days by default. Check yours if the forest is old.
  DO FIRST **Free scan checks part of this:** Stale AD Backup · No Domain Controller Redundancy
  The scan checks how old your last AD backup is and that you have more than one DC. Only a test restore tells you a backup works.
  Sources: Microsoft · DISA STIG V-243493

- [ ] **Turn on the AD Recycle Bin before you start cleaning up**
  Deleted objects come back with their group memberships intact, so a cleanup mistake is a quick undo. Once it's on, it stays on. Protect OUs from accidental deletion while you're there.
  DO FIRST **Free scan checks this:** Recycle Bin is Disabled · Accidental Deletion Protection Not On OUs
  Deep dives: AD Recycle Bin · Accidental deletion protection Source: Microsoft

02 Take away the easy wins

0 of 10 done

Attackers check these in their first hour on a network, usually with free tools anyone can download.

- [ ] **Require Kerberos pre-authentication on every account**
  Without it, anyone can ask a DC for data encrypted with the account's password and crack it offline. That's AS-REP roasting. If an app truly needs it off, give that account a long random password and keep it out of admin groups.
  DO FIRST **Free scan checks this:** Accounts with Kerberos Pre-Authentication Disabled
  Deep dive: AS-REP roasting Source: ASD/CISA/NSA

- [ ] **Get passwords out of Group Policy and AD attributes like descriptions**
  Any domain user can read both. Old Group Policy Preferences passwords sit in SYSVOL behind a key Microsoft published years ago.
  DO FIRST **Free scan checks this:** Password in GPO · Possible Passwords in Account Descriptions · Possible Password in AD Attributes
  Deep dives: GPP passwords · Passwords in AD descriptions Sources: ASD/CISA/NSA · NSA/CISA top 10

- [ ] **Clear the "password not required" and reversible encryption flags**
  The first lets an account have a blank password. The second keeps a copy of the password in AD that can be turned back into plain text. That copy stays until the password changes, so reset those passwords after you clear the flag.
  DO FIRST **Free scan checks this:** Accounts with No Password Requirement · Accounts with reversible passwords · GPO Enables reversible password use · Pre-Created Computer Accounts Detected
  Deep dives: Password not required · Reversible encryption Source: CIS Benchmark

- [ ] **Keep SPNs off privileged accounts and remove SPNs nobody uses**
  Any domain user can request a ticket for an account with an SPN and crack it offline. If that account is a Domain Admin, that's the whole domain.
  DO FIRST **Free scan checks this:** Accounts Vulnerable to Kerberoasting
  Deep dive: Kerberoasting Sources: ASD/CISA/NSA · Microsoft

- [ ] **Turn off LLMNR and NetBIOS name resolution**
  LLMNR and NBT-NS let anyone on the same subnet answer a name lookup and collect a hash to crack or relay.
  DO FIRST **Free scan checks part of this:** LLMNR Enabled
  The scan checks the LLMNR policy. NetBIOS is set per network adapter or through DHCP, so check that one on your machines.
  Deep dive: LLMNR and NBT-NS Source: NSA/CISA top 10

- [ ] **Move service accounts to gMSAs or give them random passwords of 30+ characters**
  Kerberoasting only pays off when the password can be cracked. A gMSA gets a long random password that Windows rotates for you.
  DO SOON **Free scan checks part of this:** Accounts Vulnerable to Kerberoasting · gMSA Not In Use · gMSA with Stale Password · gMSA Password Readable by Unprivileged Principals
  The scan flags roastable accounts and gMSA problems. It can't see how long a regular service account's password is.
  Deep dives: Readable gMSA passwords · gMSA password rotation Sources: ASD/CISA/NSA · Microsoft

- [ ] **Deploy LAPS everywhere and limit who can read the passwords**
  A shared local admin password lets an attacker hop from one machine to all of them. Use the built-in Windows LAPS, since the old MSI version is deprecated.
  DO SOON **Free scan checks this:** LAPS Not In Use · Risky LAPS read permissions
  Deep dive: LAPS Sources: Microsoft · DISA STIG V-243471

- [ ] **Set a minimum password length of 14 or more, with longer minimums for admins and service accounts**
  Short passwords fall to password spraying. Once a hash leaks, they crack fast offline as well.
  DO SOON **Free scan checks part of this:** Password Policy Set for Less than 8 Characters · Fine-Grained Password Policy Not Applied
  The scan flags a domain policy that allows fewer than 8 characters. Getting it to 14 or more is on you.
  Sources: CIS Benchmark · ASD/CISA/NSA

- [ ] **Set the account lockout threshold to 5 or fewer, never 0**
  Lockout caps how many guesses a password spray gets against each account. Use a fine-grained password policy to keep break-glass accounts from locking out. Before you lower it, look for accounts that already rack up bad password attempts. Otherwise the help desk will be clearing lockouts all week.
  DO SOON **Check this by hand**
  Sources: CIS Benchmark · ASD/CISA/NSA

- [ ] **Find accounts whose passwords never expire or haven't changed in years**
  An old password has had years to end up in a breach dump or a cracked hash list.
  ONGOING **Free scan checks this:** Accounts with Non-Expiring Passwords · Accounts With Stale Passwords
  Deep dives: Non-expiring passwords · Stale passwords Source: CIS Benchmark

03 Shrink Tier 0

0 of 6 done

Admin groups collect people over the years and nobody remembers adding half of them. Every account in them is a way to own the forest.

- [ ] **Cut Domain Admins and Enterprise Admins down to a few named people and keep Schema Admins empty**
  Microsoft's tier model says a common target is fewer than five people with Domain Admin-level access. Give any service account in there the specific rights it needs before you pull it out.
  DO FIRST **Free scan checks this:** High Number of Privileged Users · Schema Admins Group Not Empty · Computer Account Detected in Privileged Group · Privileged Group Contains Foreign Security Principal
  Deep dives: Schema Admins · Admin group membership Sources: Microsoft · DISA STIG V-243467

- [ ] **Empty the operator groups and DnsAdmins**
  Microsoft counts Backup Operators and Server Operators as Tier 0. Account Operators, Print Operators and DnsAdmins have known routes to Domain Admin. Find out what each member is for first, since backup software often runs as a member of Backup Operators.
  DO FIRST **Free scan checks this:** Operator Groups In Use · DNS Admins Group Not Empty
  Deep dives: Operator groups · DnsAdmins Source: Microsoft

- [ ] **Remove stale admin accounts and rotate passwords on the ones you keep**
  If nobody uses an admin account, nobody notices when an attacker starts using it. An admin password that never changes keeps any old leak working.
  DO SOON **Free scan checks this:** Inactive Privileged Users · Disabled Privileged Accounts · Privileged Users with Stale Passwords · Non-Expiring Passwords in Domain Admins Group · Possible Duplicated Accounts
  Deep dives: Inactive admin accounts · Stale passwords · Duplicate accounts Sources: CIS Controls 5.3 · NSA/CISA top 10

- [ ] **Put admins in Protected Users and mark them as sensitive so they can't be delegated**
  Their sign-ins can't use NTLM or weak Kerberos encryption and their credentials don't get cached or delegated. Test with one admin first.
  DO SOON **Free scan checks this:** Protected Users Group Not Utilized · Privileged Users Allowed to Be Delegated
  Deep dives: Protected Users · Sensitive flag Sources: Microsoft · DISA STIG V-243477

- [ ] **Lock down the built-in Administrator and Guest accounts**
  Their SIDs are well known, so they're the first accounts attackers try. Keep Guest disabled and save Administrator for recovery.
  DO SOON **Free scan checks this:** Built-in Administrator account used recently · Guest Account Enabled
  Sources: Microsoft · CIS Controls 4.7

- [ ] **Reset the krbtgt password twice every 180 days or sooner, at least 10 hours apart**
  Whoever steals the krbtgt key can forge a Golden Ticket for any account. That key keeps working until the password has been reset twice. Check that the first reset has replicated, then wait out the max ticket lifetime before the second so live tickets don't break. It's 10 hours by default.
  DO SOON **Free scan checks this:** Stale krbtgt Account Password
  Deep dive: krbtgt resets Sources: Microsoft · CISA

04 Fix delegation and dangerous permissions

0 of 7 done

Most of these don't show up in ADUC unless you go looking. They're behind a lot of the paths to Domain Admin we find on pentests.

- [ ] **Remove unconstrained delegation from everything that isn't a DC**
  Anyone who signs in to that machine leaves a reusable ticket behind. Coercion tricks can even force a DC to do it. Move anything that still needs delegation to constrained delegation or RBCD first.
  DO FIRST **Free scan checks this:** Unconstrained Delegations Detected
  Deep dive: Unconstrained delegation Sources: DISA STIG V-243478 · Microsoft

- [ ] **Limit DCSync rights to DCs and the few accounts that truly need them**
  Anyone with replication rights can pull every password hash in the domain. The krbtgt hash comes with them. Old Exchange installs are a common culprit.
  DO FIRST **Free scan checks this:** Risky DCSync Permissions · Exchange Not Hardened
  Sources: ASD/CISA/NSA · Microsoft

- [ ] **Audit AdminSDHolder and the permissions and owners on privileged objects**
  Attackers love AdminSDHolder as a backdoor because an extra permission on it gets copied onto every protected admin account and group within the hour.
  DO FIRST **Free scan checks this:** Risky AdminSDHolder Permissions · Dangerous Control Over Privileged Objects · Privileged Objects With Unprivileged Owners · Non-Standard Domain Controller Owner · Unknown Account within Delegation
  Deep dives: AdminSDHolder · Who owns your DCs · Privileged object owners Source: Microsoft

- [ ] **Check who can write msDS-KeyCredentialLink on admins and DCs**
  Write access there lets someone add their own key and sign in as that account without its password. The trick is called shadow credentials.
  DO FIRST **Free scan checks this:** Shadow Credential Write Access on Privileged Objects
  Source: ASD/CISA/NSA

- [ ] **Set ms-DS-MachineAccountQuota to 0**
  By default any user can add up to 10 computers to the domain. That's a common first step in relay and RBCD attacks. Give the people and tools that join machines the right to create computer objects in their OUs first. Otherwise their joins start failing.
  DO FIRST **Free scan checks this:** Non-administrative users can add computer accounts
  Deep dive: MachineAccountQuota Sources: ASD/CISA/NSA · DISA STIG WN25-DC-000350

- [ ] **Review constrained delegation and RBCD, then turn off protocol transition where you don't need it**
  Protocol transition lets a compromised service account impersonate any user to the services it can delegate to. That includes your admins.
  DO SOON **Free scan checks this:** Protocol Transition Delegation to Domain Controllers · Constrained Delegation Detected · Resource-Based Constrained Delegation Configured · Constrained Delegation on Accounts Without SPNs
  Deep dives: Constrained delegation · RBCD Source: Microsoft

- [ ] **Lock down who can edit GPOs and the scripts and files they deploy**
  Whoever can edit a GPO that applies to DCs or admin workstations can run code on them.
  DO SOON **Free scan checks this:** Risky GPO Control Permissions · Risky GPO Login Script Permissions · Overly permissive GPO deployed file · Risky GPO Assignment to Local Groups · Dangerous User Rights Assigned by GPO
  Source: DISA STIG WN25-DC-000090

05 Lock down AD CS

0 of 6 done

Skip this group if you don't run Active Directory Certificate Services. If you do, one bad template can take a regular user to Domain Admin. The free scan checks ESC1 through ESC17, apart from ESC12.

- [ ] **Fix risky certificate templates**
  A template that lets the requester name the subject or use the certificate for any purpose can hand a regular user a certificate for an admin or a server.
  DO FIRST **Free scan checks this:** ESC1 · ESC2 · ESC3 · ESC13 · ESC15 · ESC17
  Deep dive: ADCS ESC1 · ADCS ESC2 · ADCS ESC3 · ADCS ESC13 · ADCS ESC15 · ADCS ESC17
  Sources: ASD/CISA/NSA · NSA/CISA top 10

- [ ] **Restrict who can modify templates, PKI objects and the CA**
  Write access to a template or the CA lets an attacker build their own ESC1.
  DO FIRST **Free scan checks this:** ESC4 · ESC5 · ESC7
  Deep dive: ADCS ESC4 · ADCS ESC5 · ADCS ESC7 Sources: ASD/CISA/NSA · NSA/CISA top 10

- [ ] **Remove EDITF_ATTRIBUTESUBJECTALTNAME2 from your CAs and keep the SID extension on**
  That flag lets any request name another user. Turning off the SID extension strips the SID that ties a certificate to its owner.
  DO FIRST **Free scan checks this:** ESC6 · ESC16
  Deep dive: ADCS ESC6 · ADCS ESC16 · Weak certificate mappings Sources: ASD/CISA/NSA · Microsoft

- [ ] **Protect web and RPC enrollment from NTLM relay**
  A coerced DC sign-in relayed to web enrollment gets the attacker a certificate for that DC. From there they can take the domain.
  DO FIRST **Free scan checks this:** ESC8 · ESC11
  Deep dive: ADCS ESC8 · ADCS ESC11 Source: NSA/CISA top 10

- [ ] **Fix weak certificate mappings**
  Patched DCs have enforced strong mapping since February 2025. The opt-out went away in September 2025, so weak mappings now fail the logon instead of letting someone in. What's left is DCs missing those updates, Schannel still allowing UPN mapping and anyone who can write altSecurityIdentities on an admin. The last two are ESC10 and ESC14.
  DO SOON **Free scan checks this:** ESC9 · ESC10 · ESC14 · Accounts with Weak Certificate Mappings
  Deep dive: ADCS ESC9 · ADCS ESC10 · ADCS ESC14 · Weak certificate mappings Source: Microsoft

- [ ] **Give your CAs DC-level protection, with the CA key in an HSM and backups locked down**
  Whoever steals a CA's private key can mint a certificate for anyone. That's a Golden Certificate and resetting passwords won't undo it.
  DO SOON **Check this by hand**
  Sources: ASD/CISA/NSA · Microsoft

06 Retire legacy auth and stop relays

0 of 7 done

Most of Microsoft's 2025 and 2026 hardening changes land here, so some of this may already be on by default. Check before you assume either way.

- [ ] **Set LAN Manager authentication to "Send NTLMv2 response only. Refuse LM & NTLM"**
  LM and NTLMv1 responses can be cracked back to a password or hash. DCs on the default setting still accept them. Check your DCs' 4624 events for NTLM V1 sign-ins first, because anything still using it fails once you refuse it.
  DO FIRST **Free scan checks this:** NTLMv1 or LM is Permitted · LM Hash Storage Allowed
  Deep dive: Disable NTLMv1 · NTLMv1 SSO blocked Sources: DISA STIG WN25-SO-000310 · ASD/CISA/NSA

- [ ] **Require SMB signing on DCs, then on every other Windows machine**
  Unsigned SMB lets an attacker relay a captured sign-in to another server. Windows 11 24H2 Pro, Enterprise and Education require it by default. Most member servers still don't require it on incoming connections. Test NAS boxes and other third-party SMB devices first, since the ones that can't sign will stop working.
  DO FIRST **Free scan checks this:** Domain Controller with SMB Signing Not Required · Computer with SMB Signing Not Required · Hardened UNC Paths Not Enforced
  Deep dives: SMB signing · SMB signing bypass Sources: Microsoft · NSA/CISA top 10

- [ ] **Require LDAP signing on DCs and clients**
  Unsigned LDAP binds can be relayed to change AD objects, like setting up RBCD on a computer. Before you enforce it, check the Directory Service log for events 2887 and 2889. They show what's still doing unsigned or simple binds, which stop working the moment signing is required. Windows Server 2025 only requires it by default on new deployments, not upgrades.
  DO FIRST **Free scan checks this:** LDAP Signing Not Enforced on Domain Controllers · LDAP Client Signing Disabled by GPO
  Deep dives: LDAP signing · LDAP signing bypass Source: Microsoft

- [ ] **Remove RC4 and DES from Kerberos on every account and trust**
  RC4 tickets are keyed with the account's unsalted NT hash, so they crack fast. Since the April 2026 updates, patched DCs assume AES for accounts with no setting. The July 2026 updates took the rollback away. Find any account with no setting that still depends on RC4 and fix it, because a patched DC won't hand it RC4 anymore.
  DO FIRST **Free scan checks this:** DES/RC4 Support Enabled · Accounts with SPNs Not Supporting AES · User Accounts with DES Enabled · AES Not Enabled on Trust
  Deep dives: RC4 in Kerberos · DES and RC4 support · DES-enabled accounts
  Sources: Microsoft · DISA STIG WN25-SO-000290

- [ ] **Set LDAP channel binding to "Always" on DCs**
  Channel binding protects LDAPS, which LDAP signing doesn't. Watch for event 3039 first so you know which clients would break.
  DO SOON **Free scan checks this:** LDAPS Channel Binding Not Enforced
  Deep dive: LDAP channel binding Sources: Microsoft · CIS Benchmark

- [ ] **Remove SMBv1 from DCs, then from everything else**
  SMBv1 is how WannaCry spread and it has none of the later versions' protections. Turn on SMBv1 auditing first and watch for event 3000 to find the old devices that still need it before they break.
  DO SOON **Free scan checks part of this:** Domain Controllers with SMBv1 Enabled
  The scan checks your DCs. Member servers and old devices on the network are on you.
  Deep dive: SMBv1 on DCs Sources: ASD/CISA/NSA · Microsoft

- [ ] **Audit where NTLM is still used and start moving those apps to Kerberos**
  NTLM is what most relay attacks ride on. Microsoft plans to turn network NTLM off by default in the next major Windows Server release.
  `ONGOING` **Check this by hand**
  Source: Microsoft

07 Harden the domain controllers

`0 of 7 done`

Whoever controls a DC controls the domain. These items cut down what can reach your DCs and what an attacker could take from them.

- [ ] **Patch DCs on a tight schedule and reboot them**
  DC bugs get exploited fast. Several of the 2025 and 2026 hardening changes on this list only arrive through updates.
  `DO FIRST` **Free scan checks this:** Domain Controller with Stale Update
  Sources: Microsoft · NSA/CISA top 10

- [ ] **Turn off the Print Spooler and WebClient services on DCs**
  The spooler lets any domain user make a DC authenticate to a machine they pick. WebClient makes those forced sign-ins easier to relay.
  `DO FIRST` **Free scan checks this:** Print spooler service is enabled on a Domain Controller · WebClient Service Running on Domain Controllers
  Deep dive: Print Spooler on DCs Sources: ASD/CISA/NSA · CIS Benchmark

- [ ] **Retire unsupported Windows and raise the functional level to 2016 or later**
  Unsupported systems don't get fixes. Old DCs also hold the whole domain back from newer protections, so start with those. Windows Server 2016 leaves extended support in January 2027, so don't plan new DCs on it.
  `DO SOON` **Free scan checks this:** Legacy Operating System on Domain Controller · Legacy Operating Systems Detected · Legacy Domain Functional Level Detected · NTFRS SYSVOL Replication Active
  Deep dive: Legacy operating systems Sources: Microsoft · DISA STIG V-243480

- [ ] **Keep DCs dedicated to AD DS, with no browsing and no outbound internet**
  Every extra app or web session on a DC is another way into Tier 0.
  `DO SOON` **Check this by hand**
  Sources: Microsoft · DISA STIG V-243475

- [ ] **Turn on LSA protection on DCs and limit who can sign in to them**
  LSA protection makes dumping credentials from memory harder. Fewer sign-ins also leave fewer credentials to dump. Run it in audit mode first and check CodeIntegrity events 3065 and 3066. That way a password filter or smart card driver doesn't stop loading on your DCs.
  `DO SOON` **Check this by hand**
  Sources: Microsoft · CIS Benchmark

- [ ] **Make sure DC machine passwords rotate and clean out DCs that no longer exist**
  A DC's computer account can replicate the whole domain, so a stolen DC password stays dangerous until it changes.
  `DO SOON` **Free scan checks this:** Stale Domain Controller Passwords · Inactive Domain Controllers · Stale Computer account passwords
  Sources: ASD/CISA/NSA · DISA STIG WN25-DC-000330

- [ ] **Keep Tier 0 accounts off every RODC's allowed list**
  An RODC caches passwords for the accounts it's allowed to. A stolen branch-office DC shouldn't hold admin credentials. Skip this one if you don't run RODCs.

  DO SOON **Free scan checks this:** Privileged Groups Missing From RODC Denied List · RODC Privileged Users Exposed · RODC Privileged Groups Can Be Exposed

  Deep dive: RODC password replication policy Source: DISA STIG V-243489

08 Trusts, SID History and anonymous access

0 of 4 done

Old trusts and migration leftovers tend to outlive everyone who knew why they were there.

- [ ] **Keep SID filtering on for every external and forest trust and strip risky trust attributes**
  Without it, whoever controls the other domain can claim membership in your admin groups through SID History.

  DO FIRST **Free scan checks this:** Trust without SID Filtering · Dangerous Trust Attributes Detected · NT4 Compatible Trust

  Deep dive: SID History Source: DISA STIG V-243484

- [ ] **Clear out SID History left over from migrations**
  A privileged SID in an ordinary account's SID History makes it an admin that no group membership shows.

  DO FIRST **Free scan checks this:** Privileged SIDs in sIDHistory · Accounts and Groups with SID History · Account Migrated from Non-Existent Domain

  Deep dive: SID History Source: ASD/CISA/NSA

- [ ] **Turn off anonymous access to AD**
  Anonymous binds let anyone who can reach a DC list your users and groups without a password. Check dSHeuristics, then take Anonymous Logon and Everyone out of Pre-Windows 2000 Compatible Access.

  DO FIRST **Free scan checks this:** Anonymous Access to AD Enabled · Anonymous NSPI Access Permitted · Insecure dSHeuristics Configuration · Over permissioned "Pre-Windows 2000 Compatible Access" Group · Custom "Pre-Windows 2000 Compatible Access" Group Membership

  Deep dive: Anonymous LDAP access · Pre-Windows 2000 Compatible Access Sources: DISA STIG V-243503 · V-243486

- [ ] **Use selective authentication on outgoing forest trusts and delete trusts nobody uses**
  Every trust is a way in and selective authentication limits it to the servers you allow. Before you switch it on, grant Allowed to Authenticate on the servers people from the other forest use. Otherwise they lose access right away.

  DO SOON **Free scan checks part of this:** Inactive Trust Detected · Trust Accounts with Stale Passwords
  The scan finds trusts that look unused and trust passwords that stopped rotating. Whether a trust uses selective authentication is yours to check.

  Sources: DISA STIG V-243485 · Microsoft

09 Keep admin work off everyday machines

0 of 5 done

This is the slow one. Tiering takes months in most shops, so start early and roll it out in pieces.

- [ ] **Give every admin a separate admin account with no mailbox and no web browsing**
  If an admin's everyday account gets phished, the attacker shouldn't get the domain with it.

  DO FIRST **Free scan checks part of this:** Administrator Accounts With Email Addresses
  The scan flags admin accounts that have an email address. Whether anyone browses the web with them is yours to check.

  Deep dive: Admin group membership Sources: CIS Controls 5.4 · DISA STIG V-243468

- [ ] **Block Tier 0 accounts from signing in to workstations and member servers**
  Every sign-in to a lower-tier machine leaves credentials there for an attacker to lift. Move any services and scheduled tasks that run as Tier 0 accounts first, because the deny rights stop those from running.
  `DO SOON` **Check this by hand**
  Source: Microsoft

- [ ] **Do Tier 0 admin work only from privileged access workstations**
  If the machine you're typing on is compromised, so is every server you connect to from it.
  `DO SOON` **Check this by hand**
  Source: Microsoft

- [ ] **Require phishing-resistant MFA for admin access**
  A stolen password alone shouldn't be enough to act as Tier 0. Smart card accounts still have an NT hash behind them, so rotate it on a schedule.
  `DO SOON` **Free scan checks part of this:** Smart Card Required Accounts with Stale Passwords
  The scan checks that smart card accounts still get their password rotated. MFA is enforced outside AD, so check it wherever you set it up.
  Sources: CIS Controls 6.5 · DISA STIG V-243476

- [ ] **Grant admin rights just in time instead of permanently**
  An account that's always in Domain Admins is a prize any day of the week. If the rights only show up when someone asks for them, a stolen password gets an attacker a lot less.
  `DO SOON` **Check this by hand**
  Source: Microsoft

10 Where AD meets Entra ID

`0 of 5 done`

If you sync to Entra ID, your AD and your tenant can each be used to attack the other.

The scan's hybrid checks are on paid plans. They read what Entra Connect leaves in on-prem AD and never touch your tenant.

- [ ] **Protect Entra Connect servers and the sync account like DCs**
  With password hash sync, the sync account can pull password hashes the way a DC does. Whoever owns the Entra Connect server can own AD.
  `DO FIRST` **Checked on paid plans:** Synchronization Account Is Privileged · Synchronization Account Can Reset Privileged Passwords · Synchronization Account Can Modify Privileged Groups · Synchronization Principal Can Control Tier 0 Objects · Synchronization Account Has Excessive AD Permissions · Synchronization Permissions Reach AdminSDHolder-Protected Objects · Non-Tier 0 Principal Controls Synchronization Account · Synchronization Account Is Delegatable · Multiple Synchronization Accounts Hold DCSync Rights
  Deep dives: Tenant to AD · Hybrid attack surface Source: Microsoft

- [ ] **Remove old sync accounts and rotate the active one's password**
  Leftover sync accounts keep their rights long after anyone remembers they exist. When you rotate the password, put the new one into Entra Connect's Synchronization Service Manager right away. If you don't, sync stops.
  `DO SOON` **Checked on paid plans:** Inactive or Orphaned Synchronization Account · Multiple Enabled Synchronization Accounts Detected · Disabled Synchronization Account Retains Sensitive Permissions · Synchronization Account Password Is Stale
  Sources: CIS Controls 5.3 · Microsoft

- [ ] **Roll over the Seamless SSO key at least every 30 days and lock down AZUREADSSOACC$**
  Anyone holding that key can forge Kerberos tickets that Entra ID accepts for your synced users. Run the rollover only once per forest each time. Running it twice breaks Seamless SSO until users' tickets expire.
  `DO SOON` **Checked on paid plans:** Stale Entra Seamless SSO Account Password · Unauthorized Control Over the Entra Seamless SSO Account · Unexpected Owner of the Entra Seamless SSO Account · Dangerous Kerberos Delegation on the Entra Seamless SSO Account · Resource-Based Constrained Delegation on Entra Seamless SSO Account · Entra Seamless SSO Account Is Not Protected from Delegation · Entra Seamless SSO Account Supports Weak Kerberos Encryption · Unexpected SPNs on Entra Seamless SSO Account · Multiple Entra Seamless SSO Account Objects Detected
  Deep dive: Hybrid attack surface Source: Microsoft

- [ ] **Keep admins out of the AzureADKerberos password replication policy**
  With cloud Kerberos trust, that policy decides which accounts can sign in to AD with tickets Entra ID issues. Microsoft blocks admins by default and says not to relax it.
  `DO SOON` **Checked on paid plans:** AzureADKerberos Password Replication Policy Exposes Privileged Accounts · Unauthorized Control Over AzureADKerberos Object · Dangerous Delegation on AzureADKerberos Object
  Deep dive: Tenant to AD Source: Microsoft

- [ ] **If you still run AD FS, protect it like a DC and rotate its token-signing certificates**
  A stolen token-signing key lets an attacker forge sign-ins to every app that trusts AD FS. That's Golden SAML. Before a new certificate goes primary, give it to Entra ID if you federate with it. Do the same for partners that don't read your federation metadata. Miss one and those sign-ins fail.
  `DO SOON` **Check this by hand**
  Sources: ASD/CISA/NSA · Microsoft

11 Log what matters

`0 of 4 done`

The scan checks that the audit settings exist. Collecting the events and alerting on them is a job for your SIEM or detection tools.

- [ ] **Apply the advanced audit policy to DCs and audit changes to AdminSDHolder and other key objects**
  Without these events, DCSync and changes to admin groups leave nothing behind to investigate.
  `DO SOON` **Free scan checks part of this:** Insufficient Domain Controller Logging
  The scan checks the advanced audit policy your DCs get. Auditing on AdminSDHolder and other key objects is set separately, so check those yourself.
  Deep dive: DC audit policy Sources: Microsoft · DISA STIG WN25-DC-000210

- [ ] **Turn on PowerShell script block and module logging**
  A lot of AD attack tooling runs through PowerShell. These logs show exactly what ran.
  `DO SOON` **Free scan checks this:** Weak PowerShell Logging
  Deep dive: PowerShell logging Sources: ASD/CISA/NSA · CIS Controls 8.8

- [ ] **Send DC, CA, AD FS and Entra Connect logs to a central SIEM and review them**
  Logs that only live on a DC can be wiped by whoever takes the DC.
  `ONGOING` **Check this by hand**
  Sources: ASD/CISA/NSA · CIS Controls 8.9

- [ ] **Plant canary accounts that nobody should ever touch**
  A decoy that alerts the moment someone requests its ticket or tries its password turns Kerberoasting and spraying into loud, easy-to-spot events.
  `ONGOING` **Check this by hand**
  Source: ASD/CISA/NSA

12 Plan for the bad day

0 of 4 done

If someone does get Domain Admin, these decide how long you're down.

- [ ] **Encrypt DC backups and keep an offline copy that only a few people can touch**
  Anyone who gets a copy of a DC backup can pull the password hashes out of it, so protect it like a DC.
  DO SOON **Check this by hand**
  Sources: ASD/CISA/NSA · CIS Controls 11.4

- [ ] **Write a forest recovery plan and test it**
  Forest recovery is a long process with a strict order. You don't want to be learning it in the middle of an incident.
  DO SOON **Check this by hand**
  Sources: Microsoft · CIS Controls 11.5

- [ ] **Change the DSRM password at least once a year or let Windows LAPS manage it**
  DSRM is a local admin account on every DC. Its password is often whatever someone typed during promotion.
  DO SOON **Check this by hand**
  Sources: DISA STIG V-243479 · Microsoft

- [ ] **Re-run your assessment after every fix and on a schedule**
  AD drifts as people add accounts and hand out rights. Re-running the assessment is how you know a fix stuck.
  ONGOING **Run the free scan again after each fix.** Free keeps your latest scan only. Scheduled scans, scan history and remediation tracking start on Standard.
  Source: Microsoft

Where this Active Directory security checklist comes from

- Microsoft's AD security guidance, including its December 2025 threat guidance and the 2026 Kerberos and NTLM changes
- The ASD, CISA and NSA guide Detecting and mitigating Active Directory compromises
- The NSA and CISA top ten misconfigurations advisory
- CIS Controls v8.1 and the CIS Benchmarks
- The DISA Active Directory and Windows Server 2025 STIGs

Check names link to our checks library. We last reviewed this page on October 30, 2026.
